FACULTAD DE DEFENSA NACIONAL — FADENA

Licenciatura en Ciberdefensa | Tecnología Operativa 2026

Documento de Cátedra N°18 — Vectores de Ataque en Infraestructura Física: Análisis Forense de Stuxnet e Industroyer

Sección 6 — Actividades de Verificación y Análisis (cierre de la materia)

Actividad 1 — Stuxnet mapeado al ICS Cyber Kill Chain

a) Las ocho fases y el componente de Stuxnet correspondiente

Fase	Componente de Stuxnet (Tabla 2, Sección 2.1)
1. Reconocimiento	La lógica de fingerprinting/targeting refleja un reconocimiento previo extremadamente preciso: conocimiento previo del modelo exacto del PLC S7-315-2 y la disposición de variadores de las cascadas de Natanz.
2. Armamento y entrega	El worm USB con cuatro días cero (incluido CVE-2010-2568), diseñado para propagarse sin conexión a internet y atravesar el air gap.
3. Explotación	La ejecución del exploit .LNK al insertar el medio extraíble, obteniendo ejecución de código en el sistema objetivo.
4. Instalación/Modificación	El rootkit en modo kernel firmado con certificados robados de Realtek y JMicron, ocultando los archivos del malware del sistema operativo.
5. Comando y Control (C2)	Canales de actualización remota que permitieron recibir nuevas versiones del payload durante la propagación (documentado por Symantec).
6. Desarrollo y validación del ataque ICS	La lógica de fingerprinting/targeting, en su función de validación: el payload permanecía inerte salvo coincidencia exacta de huella técnica — evidencia de pruebas previas en cascada de prueba.
7. Entrega e instalación de la capacidad ICS	La instalación del módulo man-in-the-middle de telemetría sobre los módulos de entrada del PLC S7-417, distinto del malware de intrusión inicial.
8. Ejecución e impacto sobre el proceso físico	El replay de los 13 días de valores normales hacia WinCC combinado con la manipulación real de los variadores de frecuencia Vacon/Fararo Paya.

b) Mejor oportunidad de detección/interrupción

La fase con mejor oportunidad real de detección en 2009-2010 fue la Fase 2 (Armamento y entrega) — el worm USB. A diferencia de las fases posteriores, que requieren conocimiento profundo y específico del proceso OT, el control de medios extraíbles ya era tecnología disponible y bien entendida en 2009: políticas de bloqueo/whitelisting de USB, deshabilitación de autorun y monitoreo de transferencia de archivos en estaciones air-gapped. La Nota de Ciberdefensa de la Sección 2.1 confirma esto indirectamente: el mismo mecanismo de propagación que atravesó el air gap fue el que permitió a Stuxnet escapar de Natanz hacia más de cien mil sistemas — un comportamiento de red detectable con controles de IT estándar, no con capacidades especializadas de OT.

c) Por qué la fase de ejecución fue la más difícil de detectar en tiempo real

Esta fase fue indetectable en tiempo real porque el ataque neutralizó la única capa de supervisión que normalmente detectaría una anomalía de proceso: el operador humano. El mecanismo MITM de telemetría grabó 13 días de valores normales y los reprodujo hacia WinCC exactamente durante la ejecución del ataque real — el operador veía parámetros dentro de lo esperado, sin discrepancia visual que activara su atención. Esto es la aplicación exacta de la doctrina de Integridad del Doc. N°17,

Sección 1.1: el ataque no ocultó el comando malicioso, ocultó el efecto del comando sobre la representación del proceso que el humano podía observar. No existe control de detección basado en inspección visual humana que funcione cuando la fuente misma de esa inspección está comprometida — la detección habría requerido una fuente de verdad independiente del HMI (sensores de vibración o temperatura con reporte directo fuera del PLC comprometido).

Actividad 2 — Comparación forense: Ucrania 2015 vs. Industroyer 2016

a) Capacidad de Industroyer innecesaria en 2015

La capacidad innecesaria en 2015 fueron los módulos de protocolo ICS nativo (IEC 101, IEC 104, IEC 61850, OPC DA) que permiten emitir comandos de apertura directamente a los IED sin pasar por el HMI. En 2015 el ataque no necesitó “hablar” el protocolo industrial porque operó la interfaz legítima HMI/SCADA con credenciales VPN robadas — el software autorizado hacía la traducción protocolar por ellos.

La inversión que esa capacidad representa para el atacante es de ingeniería inversa de protocolo y desarrollo de payload modular: construir un módulo que emita comandos IEC 61850 válidos sin pasar por ningún software de supervisión requiere entender la semántica exacta del protocolo a nivel de los IED de campo, no solo operar una interfaz gráfica. Es la diferencia entre “usar el sistema como un operador” y “ser capaz de reemplazar al sistema completo” — una capacidad reutilizable contra cualquier instalación que use esos mismos protocolos estándar.

b) ¿Cuál modelo es más difícil de detectar mediante un IDS OT?

El ataque de 2015 es más difícil de detectar mediante un IDS OT centrado en protocolo: el atacante operó el software HMI/SCADA legítimo con credenciales válidas, generando tráfico de protocolo industrial indistinguible del de un operador autorizado. Un IDS OT que monitorea semántica de protocolo no tiene ninguna señal anómala que detectar, porque el problema es de identidad (¿quién está realmente detrás del teclado?), no de protocolo.

Industroyer, en cambio, es paradójicamente más detectable por un IDS OT especializado, aun siendo automatizado: sus módulos emiten comandos directamente a los IED, sin el contexto de una sesión HMI supervisora. Un IDS OT que modela la arquitectura maestro-esclavo esperada puede flaggear comandos que no se originan desde el servidor SCADA legítimo — exactamente el tipo de detección por contexto/arquitectura que habilita la función Detect del NIST CSF (Doc. N°15, Sección 4.1) cuando existe visibilidad de protocolo en el segmento OT.

c) Dos controles de segmentación para aislar los relés SIPROTEC

Control 1 — Security Zone dedicada para relés de protección (Doc. N°15, Sección 4.2): los relés SIPROTEC deben constituir su propia Security Zone, separada de la zona de SCADA/IED general, con un conduit que permita únicamente la señalización de protección estrictamente necesaria (ej. GOOSE/IEC 61850), bloqueando el acceso desde los segmentos donde corren los módulos de protocolo de gestión que Industroyer usó para el DoS.

Control 2 — Conduit de acceso de ingeniería fuera de banda: la configuración y firmware de los relés debe administrarse únicamente desde una estación de ingeniería dedicada, conectada por un canal físicamente separado (o puerto serial local), sin ruta de red desde la LAN OT general hacia el puerto UDP 50000 explotado por Industroyer (CVE-2015-5374).

Actividad 3 — Diseño retrospectivo de CCE para las centrífugas de Natanz

a) Fase 1 — Priorización de consecuencias

Evento de consecuencia más catastrófica: falla mecánica catastrófica de los rotores de las centrífugas IR-1 por operación fuera de los límites de velocidad de diseño, sostenida o cíclica, que produce destrucción física irreversible de la cascada — sin importar si el origen es error de operador, falla del variador o manipulación deliberada.

Categorías de consecuencia activadas (Doc. N°17, Sección 2.3): Financiera (reemplazo de centrífugas), Operacional/Misión (degradación del programa de enriquecimiento) y, si la falla mecánica produce fragmentación del rotor o incendio, Seguridad humana — la regla de probabilidad no nula de fatalidad se considera catastrófica se activa también aquí.

b) Fase 2 — Ruta técnica y punto de convergencia

Ruta real: PLC (S7-417) → variador de frecuencia (Vacon/Fararo Paya) → motor → rotor.

El punto donde un comando malicioso o erróneo puede producir el evento catastrófico es la interfaz entre el PLC y el variador de frecuencia: el punto donde se fija el setpoint de velocidad de rotación. Cualquier comando que establezca una velocidad fuera de los límites mecánicos de diseño, sin importar su origen, converge en el mismo punto físico de falla — la misma lógica que el Doc. N°17 establece para Aurora: el problema no es la autenticidad del comando, es el estado físico en el que se ejecuta.

c) Fases 3 y 4 — Control de ingeniería propuesto

Mecanismo propuesto: un limitador mecánico/analógico de velocidad (overspeed/underspeed trip) — un gobernador centrífugo o un relé de protección basado en tacómetro independiente — conectado directamente al circuito de alimentación del motor, que corta físicamente la energía si la velocidad real medida excede o cae por debajo de los límites seguros, sin depender de ningún comando digital del PLC ni del variador.

Por qué habría sido efectivo incluso con la telemetría falsificada: este mecanismo mide la velocidad real del motor con un sensor propio, independiente del lazo de telemetría que Stuxnet comprometió. El ataque falsificó los valores que veía el PLC/WinCC, pero no tenía control sobre un sensor de velocidad físicamente aislado de esa cadena. Igual que el relé de sincronía de fase del caso Aurora, este limitador no consulta al PLC comprometido para decidir si debe cortar la energía: corta porque la centrífuga física está girando a una velocidad insegura, dato que ningún malware puede falsificar sin comprometer también el sensor de medición independiente.

Actividad 4 — Capstone: Base Logística Sur bajo ataque combinado Stuxnet + Industroyer

a) Cadena de ataque completa (ICS Cyber Kill Chain)

Fase	Vector explotado (Doc. N°15/16)	Mecanismo inspirado en Stuxnet/Industroyer
1. Reconocimiento	Exposición del Gateway IIoT (F) y su plataforma cloud de mantenimiento predictivo	Inteligencia previa sobre el modelo de PLC (S7-300) y disposición de los tres generadores, análoga al reconocimiento de Natanz
2. Armamento y entrega	Compromiso de la plataforma cloud del proveedor, entregado vía canal 4G del Gateway F	Actualización de firmware maliciosa por un canal legítimo — equivalente del worm USB pero vía cadena de suministro
3. Explotación	Sesión TeamViewer sin control de acceso en el HMI (C)	Explotación del acceso remoto de soporte para obtener ejecución de código en Level 1/2
4. Instalación/Modificación	Historian dual-homed (E) usado como punto de persistencia oculta	Backdoor instalado aprovechando el bridge IT/OT, oculto con credenciales y procesos legítimos del Historian
5. Comando y Control	VPN del contratista HVAC (G) terminando directo en VLAN20	Canal interactivo persistente, replicando el uso de credenciales VPN robadas de Ucrania 2015
6. Desarrollo y validación del ataque ICS	Conocimiento previo de la sincronización entre los tres generadores (A)	Desarrollo y prueba de la manipulación del breaker de acoplamiento, validada en entorno de prueba — análogo a Stuxnet
7. Entrega e instalación de la capacidad ICS	Ausencia de segmentación entre VLAN20/30 (condición 1, Nota de Ciberdefensa 1, AP N°15)	Módulo MITM de telemetría sobre los PLCs A, más módulo de DoS contra el relé de protección de sincronización — réplica del módulo SIPROTEC
8. Ejecución e impacto	Punto de convergencia físico (cierre del breaker de acoplamiento fuera de fase)	Cierre malicioso del breaker fuera de sincronía (tipo Aurora) con telemetría falsificada (tipo Stuxnet) mientras el DoS neutraliza el relé de protección (tipo Industroyer)

b) Clasificación de riesgo

Probabilidad: Improbable — el escenario requiere capacidad de actor estatal (SL4, ISA/IEC 62443): desarrollo de payload de manipulación física específico, compromiso de cadena de suministro del proveedor, y módulo de DoS dirigido a relés de protección. No es ejecutable por un adversario SL3.

Consecuencia: Catastrófica, en al menos dos categorías (Doc. N°17, Sección 2.3): Seguridad humana (la falla mecánica por cierre fuera de fase tiene probabilidad no nula de incendio o proyección de fragmentos — automáticamente catastrófica) y Operacional/Misión (pérdida de energía crítica en sala de comunicaciones y NOC sin redundancia si los tres generadores resultan afectados).

Ubicación en la matriz (Sección 2.2): Improbable × Catastrófica = ALTO. No alcanza EXTREMO porque la probabilidad está acotada por el nivel de sofisticación requerido — pero es exactamente el cuadrante que un modelo centrado solo en probabilidad subestimaría.

c) Control que interrumpe la cadena en cada fase

Fase	Control propuesto	Documento de origen
1. Reconocimiento	Minimizar exposición pública de la arquitectura y del proveedor de mantenimiento predictivo	Doc. N°15
2. Armamento y entrega	FW-2 de la DMZ 3.5 con whitelist estricta de destino/origen, bloqueando firmware no firmado	Doc. N°15
3. Explotación	Jump Server con MFA reemplazando la sesión TeamViewer directa	Doc. N°15
4. Instalación/Modificación	Historian single-homed con réplica unidireccional (Historian Mirror)	Doc. N°15
5. Comando y Control	VPN terminando en concentrador de DMZ + Jump Server con grabación de sesión	Doc. N°15
6. Desarrollo y validación	Fase 1 de CCE aplicada previamente: documentar el cierre fuera de fase como evento inaceptable	Doc. N°17
7. Entrega e instalación ICS	Segmentación de relés de protección en su propia Security Zone con conduit restringido	Doc. N°15 / N°18 §3
8. Ejecución e impacto	Relé de sincronía de fase (sync-check relay) en el breaker de acoplamiento, independiente del estado cibernético	Doc. N°17 / N°18

El control de la Fase 8 cierra el caso integrador: aun si las siete fases anteriores fallan, el daño catastrófico —la destrucción física del generador por cierre fuera de fase— sigue sin poder materializarse, porque depende de una condición física verificada por un dispositivo que no recibe órdenes de ningún sistema potencialmente comprometido.